

Extensions

Both Burp and ZAP have extension capabilities, such that the community of Burp users can develop extensions for Burp for everyone to use. Such extensions can perform specific actions on any captured requests, for example, or add new features, like decoding and beautifying code. Burp allows extensibility through its **Extender** feature and its **BApp Store**, while ZAP has its **ZAP Marketplace** to install new plugins.

BApp Store

To find all available extensions, we can click on the **Extender** tab within Burp and select the **BApp Store** sub-tab. Once we do this, we will see a host of extensions. We can sort them by **Popularity** so that we know which ones users are finding most useful:

The BApp Store contains Burp extensions that have been written by users of Burp Suite, to extend Burp's capabilities.

Name	Installed	Rating	Popularity	Last updated	Detail
Active Scan++		☆☆☆☆☆	100%	25 Mar 2021	Active Scan++ ActiveScan++ extends Burp Suite's active and passive scanning capabilities. - Potential host header attacks (password reset po - Edge side includes - XML input handling
HTTP Request Smuggler		☆☆☆☆☆	100%	06 Aug 2021	
Logger++		☆☆☆☆☆	100%	06 Aug 2021	
Param Miner		☆☆☆☆☆	100%	06 Aug 2021	
JSON Web Tokens		☆☆☆☆☆	100%	19 Feb 2021	
Retire.js		☆☆☆☆☆	100%	24 Jun 2021	
Turbo Intruder		☆☆☆☆☆	100%	11 Aug 2021	Pro extension

Note: Some extensions are for Pro users only, while most others are available to everyone.

We see many useful extensions, take some time to go through them and see which are most useful to you, and then try installing and testing them. Let's try installing the **Decoder Improved** extension:

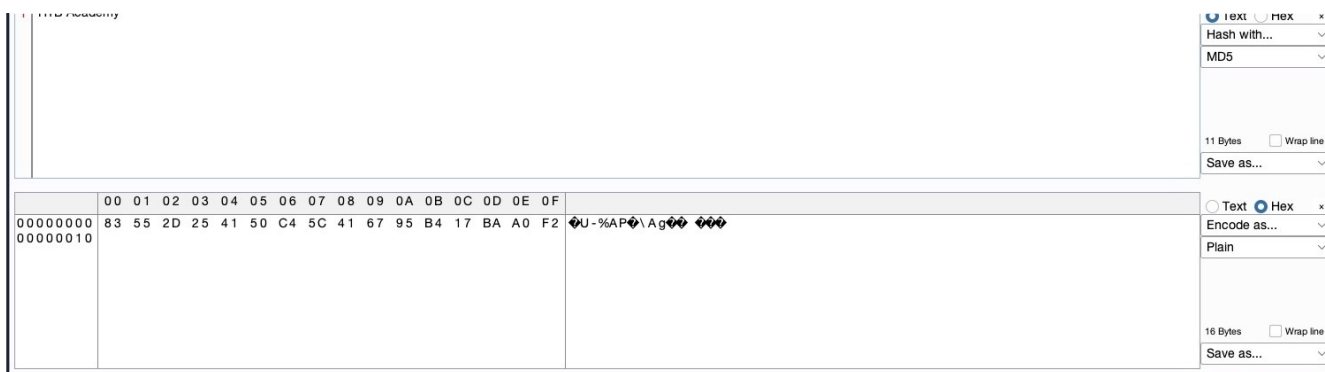
The BApp Store contains Burp extensions that have been written by users of Burp Suite, to extend Burp's capabilities.

Name	Installed	Rating	Popularity	Last updated	Detail
Decoder Improved	✓	☆☆☆☆☆	100%	19 Feb 2021	Decoder Improved Decoder Improved is a data transformation plugin for Burp Suite that better supports all of the built-in Burp Decoder modes. All of the Built-in Burp Decoder Modes Decoder Improved supports all of decoder's encoding, decoding, and hashing (SHA-256, SHA-384, and SHA-512). Tabs Like many of Burp Suite's features, Decoder Improved has support for tabs, e... Unicode Support Decoder Improved is backed by arrays of Java Bytes that do not truncate or... An Improved Hex Editor Decoder Improved comes bundled with the Delta Hexadecimal Editor, a swin... and Unicode support.
Add Custom Header		☆☆☆☆☆	100%	08 Jul 2020	
HTML5 Auditor		☆☆☆☆☆	100%	01 Jul 2014	
InQL - Introspection GraphQL S...		☆☆☆☆☆	100%	12 Aug 2021	
NoSQLi Scanner		☆☆☆☆☆	100%	01 Feb 2021	
Auth Analyzer		☆☆☆☆☆	100%	14 May 2021	
Asset Discovery		☆☆☆☆☆	100%	12 Sep 2019	
CSP Auditor		☆☆☆☆☆	100%	18 May 2020	
Attack Surface Detector		☆☆☆☆☆	100%	08 Mar 2019	
CSRF Token Tracker		☆☆☆☆☆	100%	14 Feb 2017	
Additional CSRF Checks		☆☆☆☆☆	100%	14 Dec 2018	
Taborator		☆☆☆☆☆	100%	15 Dec 2020	
Headers Analyzer		☆☆☆☆☆	100%	24 Nov 2018	
WordPress Scanner		☆☆☆☆☆	100%	29 May 2018	
Hunt Scanner		☆☆☆☆☆	100%	29 Jul 2020	

Note: Some extensions have requirements that are not usually installed on Linux/macOS/Windows by default, like `Jython`, so you have to install them before being able to install the extension.

Once we install **Decoder Improved**, we will see its new tab added to Burp. Each extension has a different usage, so we may click on any extension's documentation in **BApp Store** to read more about it or visit its GitHub page for more information about its usage. We can use this extension just as we would use Burp's Decoder, with the benefit of having many additional encoders included. For example, we can input text we want to be hashed with **MD5**, and select **Hash With>MD5**:

The screenshot shows the Burp Suite interface with the **Decoder Improved** tab selected. The interface includes a menu bar with options like Dashboard, Target, Proxy, Intruder, Repeater, Sequencer, Decoder, Comparer, Logger, Extender, Project options, User options, Learn, and Decoder Improved. Below the menu bar, there is a tab labeled "1 x ..." and a text input field containing "HTR Academy".



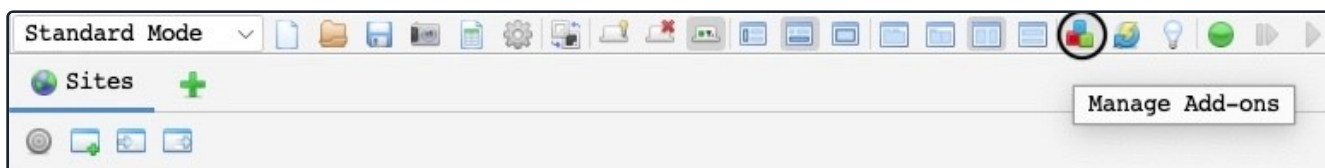
Similarly, we can perform other types of encoding and hashing. There are many other Burp Extensions that can be utilized to further extend the functionality of Burp.

Some extensions worth checking out include, but are not limited to:

.NET beautifier	J2EEScan	Software Vulnerability Scanner
Software Version Reporter	Active Scan++	Additional Scanner Checks
AWS Security Checks	Backslash Powered Scanner	Wsdler
Java Deserialization Scanner	C02	Cloud Storage Tester
CMS Scanner	Error Message Checks	Detect Dynamic JS
Headers Analyzer	HTML5 Auditor	PHP Object Injection Check
JavaScript Security	RetireJS	CSP Auditor
Random IP Address Header	Authorize	CSRF Scanner
JS Link Finder		

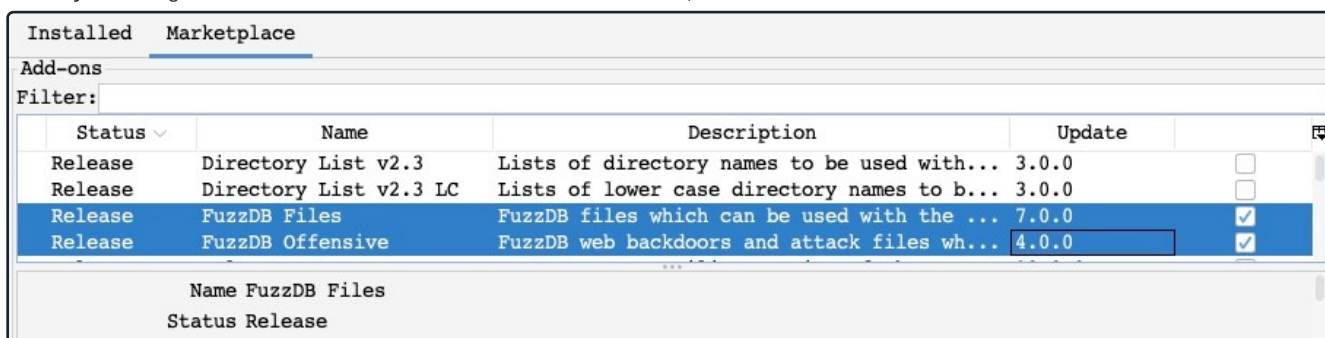
ZAP Marketplace

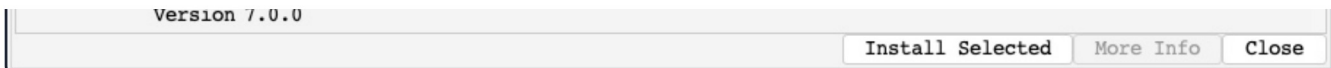
ZAP also has its own extensibility feature with the **Marketplace** that allows us to install various types of community-developed add-ons. To access ZAP's marketplace, we can click on the **Manage Add-ons** button and then select the **Marketplace** tab:



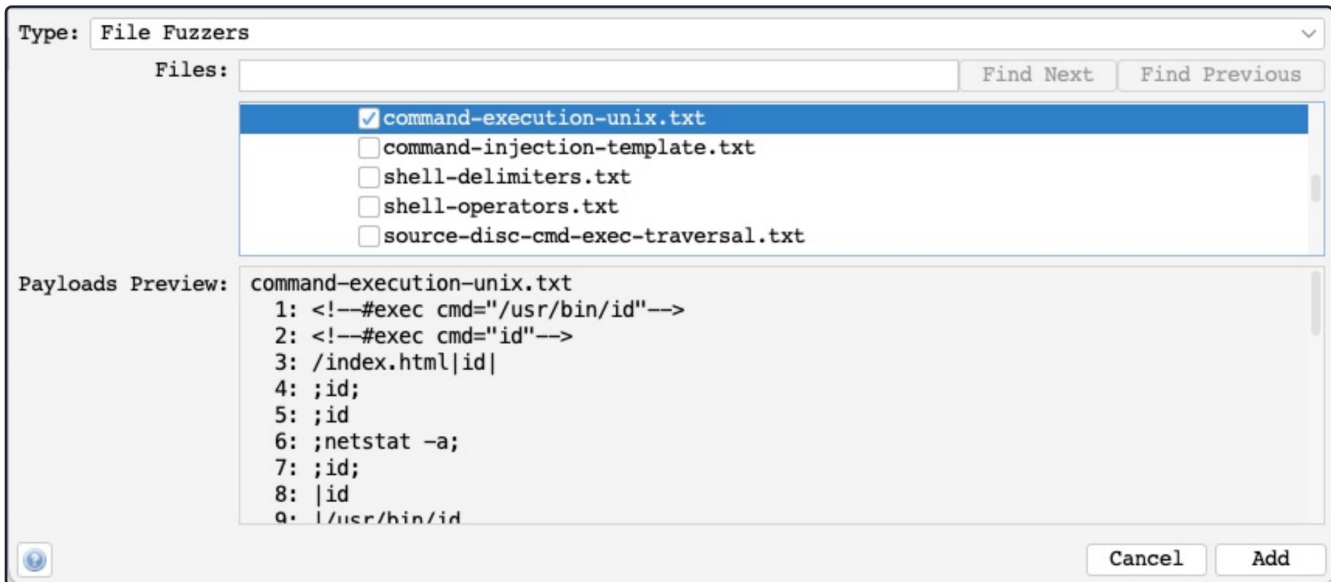
In this tab, we can see the different available add-ons for ZAP. Some add-ons may be in their **Release** build, meaning that they should be stable to be used, while others are in their **Beta/Alpha** builds, which means that they may experience some issues in their use.

Let's try installing the **FuzzDB Files** and **FuzzDB Offensive** add-ons, which adds new wordlists to be used in ZAP's fuzzer:





Now, we will have the option to pick from the various wordlists and payloads provided by FuzzDB when performing an attack. For example, suppose we were to perform a Command Injection fuzzing attack on one of the exercises we previously used in this module. In that case, we will see that we have more options in the **File Fuzzers** wordlists, including an OS Command Injection wordlist under (`fuzzdb>attack>os-cmd-execution`), which would be perfect for this attack:



Now, if we run the fuzzer on our exercise using the above wordlist, we will see that it was able to exploit it in various ways, which would be very helpful if we were dealing with a WAF protected web application:

History

Search

Alerts

Fuzzer

Output

New Fuzzer Progress: 0% HTTP - http://139.59...6.56:31133/ping 0%

Messages Sent: 34 Errors: 8 Show Errors

Export

Task ID	Message Type	Code	Reason	RTT	Size Resp. Header	Size Resp. Body	Payloads
2 Fuzzed		200 OK		4.24 s	103 bytes	0 bytes	<!--#exec cmd="id"-->
3 Fuzzed		200 OK		4.24 s	103 bytes	0 bytes	/index.html id
4 Fuzzed		200 OK		14.28 s	103 bytes	54 bytes	;id;
5 Fuzzed		200 OK		12.94 s	103 bytes	54 bytes	;id
7 Fuzzed		200 OK		13.3 s	103 bytes	54 bytes	;id;
8 Fuzzed		200 OK		11.87 s	103 bytes	54 bytes	id
9 Fuzzed		200 OK		10.96 s	103 bytes	54 bytes	/usr/bin/id
10 Fuzzed		200 OK		929 ms	103 bytes	0 bytes	id
11 Fuzzed		200 OK		912 ms	103 bytes	0 bytes	/usr/bin/id
12 Fuzzed		200 OK		1.43 s	103 bytes	0 bytes	/usr/bin/id
13 Fuzzed		200 OK		11.47 s	103 bytes	54 bytes	id;
14 Fuzzed		200 OK		10.83 s	103 bytes	54 bytes	/usr/bin/id;
15 Fuzzed		200 OK		1.45 s	103 bytes	0 bytes	id
16 Fuzzed		200 OK		702 ms	103 bytes	0 bytes	/usr/bin/id
17 Fuzzed		200 OK		694 ms	103 bytes	0 bytes	\n/bin/ls -al\n
18 Fuzzed		200 OK		687 ms	103 bytes	0 bytes	\n/usr/bin/id\n

Try to repeat the above with the first exercise in this module to see how add-ons can help in making your penetration test easier.

Closing Thoughts

Throughout this module, we have demonstrated the power of both Burp Suite and ZAP proxies and analyzed the differences and similarities between the free and pro versions of Burp and the free and open-source ZAP proxy. These tools are essential for penetration testers focused on web application security assessments but have many applications for all offensive security practitioners as well blue team practitioners and developers. After working through each of the examples and exercises in this module, attempt some web attack-focused boxes on the main Hack The Box platform and other web application security-related modules within HTB Academy to strengthen your skillsets around both of these tools. They are must-haves in your toolbox alongside Nmap, Hashcat, Wireshark, tcpdump, sqlmap, Ffuf, Gobuster, etc.

[< Previous](#)
[Next >](#)

+10 Streak pts

[✔ Mark Complete & Next](#)
[📄 Cheat Sheet](#)
[Table of Contents](#)

Getting Started

Intro to Web Proxies



Setting Up



Web Proxy

Proxy Setup



 Intercepting Web Requests



Intercepting Responses



Automatic Modification



 Repeating Requests



 Encoding/Decoding



 Proxying Tools



Web Fuzzer

 Burp Intruder



 ZAP Fuzzer



Web Scanner

Burp Scanner



 ZAP Scanner



[Extensions](#)

Skills Assessment

 Skills Assessment - Using Web Proxies

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left